LAPORAN AUDIT KEAMANAN WEBSITE

Spencer Web Security Audit Tool

Target Website	hybridsys.id
URL Lengkap	https://hybridsys.id
Tanggal Audit	19 May 2026, 16:44:36 WIB
Metode	OWASP Top 10 + CVSS Scoring
Tool	SpencerWeb v2.0
Durasi Scan	32.46 detik

SECURITY GRADE: F **SKOR: 0/100**

1. RINGKASAN EKSEKUTIF

Audit keamanan website **hybridsys.id** telah dilakukan pada tanggal **19 May 2026, 16:44:36 WIB** menggunakan Spencer Web Security Audit Tool. Audit ini menggunakan metodologi OWASP Top 10 dengan sistem penilaian risiko CVSS yang disederhanakan menjadi grade A-F.

Berdasarkan 58 pengecekan keamanan yang dilakukan, sistem mendapat grade **F** dengan skor **0/100**. Ditemukan total **33 kerentanan** yang terdiri dari:

Severity	Jumlah	Dampak
CRITICAL	5	Risiko tertinggi, harus segera diperbaiki
HIGH	10	Risiko tinggi, perbaiki dalam waktu dekat
MEDIUM	12	Risiko sedang, jadwalkan perbaikan
LOW	6	Risiko rendah, perbaikan opsional

2. METODOLOGI AUDIT

Audit ini dilakukan menggunakan pendekatan **Black-box Testing** — auditor tidak memiliki akses ke source code maupun infrastruktur internal, dan hanya berinteraksi dengan target sebagaimana attacker dari luar.

Framework yang digunakan:
• **OWASP Top 10** — standar industri untuk web application security testing
• **OWASP Testing Guide v4** — panduan teknis pengujian per kategori
• **CVSS v3.1** — Common Vulnerability Scoring System untuk penilaian risiko

Module yang dijalankan:
1. HTTP Security Headers Audit (Passive)
2. SSL/TLS Certificate Audit (Passive)
3. Sensitive File Exposure Scan (Passive)
4. CMS Detection & Version Check (Passive)
5. WordPress Plugin & Theme Scanner (Passive)
6. SQL Injection Scanner — Error, Boolean, Time-based (Active)
7. Reflected XSS Scanner (Active)
8. Stored XSS Scanner (Active)
9. CSRF Protection Checker (Active)
10. Open Port Reconnaissance (Active)

3. TEMUAN KERENTANAN

Temuan #1: File: /dump.sql	CRITICAL
Deskripsi:	EXPOSED! Database dump file — berisi seluruh data database (HTTP 200, 17126 bytes)
Rekomendasi:	Hapus file database dump dari server production

Temuan #2: File: /configuration.php	CRITICAL
Deskripsi:	EXPOSED! Joomla config exposed (HTTP 200, 17126 bytes)
Rekomendasi:	Pastikan PHP file diproses, bukan di-serve mentah

Temuan #3: File: /backup.sql	CRITICAL
Deskripsi:	EXPOSED! Database backup file exposed (HTTP 200, 17126 bytes)
Rekomendasi:	Simpan backup di lokasi yang tidak bisa diakses publik

Temuan #4: File: /db.sqlite3	CRITICAL
Deskripsi:	EXPOSED! SQLite database exposed — seluruh database bisa di-download (HTTP 200, 17126 bytes)
Rekomendasi:	Pindahkan database ke luar document root

Temuan #5: File: /database.sql	CRITICAL
Deskripsi:	EXPOSED! Database file exposed (HTTP 200, 17126 bytes)
Rekomendasi:	Hapus dari document root

Temuan #6: Strict-Transport-Security	HIGH
Deskripsi:	Memaksa browser selalu menggunakan HTTPS
Rekomendasi:	Tambahkan header: Strict-Transport-Security: max-age=31536000; includeSubDomains

Temuan #7: Content-Security-Policy	HIGH
Deskripsi:	Mencegah XSS dan injeksi konten berbahaya
Rekomendasi:	Tambahkan header CSP yang sesuai. Minimal: Content-Security-Policy: default-src 'self'

Temuan #8: File: /web.config	HIGH
Deskripsi:	EXPOSED! File konfigurasi IIS exposed (HTTP 200, 17126 bytes)
Rekomendasi:	Batasi akses ke web.config

Temuan #9: File: /nginx.conf	HIGH
Deskripsi:	EXPOSED! Konfigurasi Nginx exposed (HTTP 200, 17126 bytes)
Rekomendasi:	Jangan simpan file konfigurasi di document root

Temuan #10: File: /backup.zip	HIGH
Deskripsi:	EXPOSED! File backup ZIP exposed (HTTP 200, 17126 bytes)
Rekomendasi:	Hapus file backup dari server production

Temuan #11: File: /backup.tar.gz	HIGH
Deskripsi:	EXPOSED! File backup TAR.GZ exposed (HTTP 200, 17126 bytes)
Rekomendasi:	Hapus file backup dari server production

Temuan #12: File: /site.zip	HIGH
Deskripsi:	EXPOSED! Archive website exposed (HTTP 200, 17126 bytes)
Rekomendasi:	Hapus file archive dari server production

Temuan #13: File: /phpinfo.php	HIGH
Deskripsi:	EXPOSED! phpinfo() exposed — membocorkan versi PHP, modul, konfigurasi server (HTTP 200, 17126 bytes)
Rekomendasi:	Hapus file phpinfo.php dari server production

Temuan #14: File: /info.php	HIGH
Deskripsi:	EXPOSED! PHP info page exposed (HTTP 200, 17126 bytes)
Rekomendasi:	Hapus dari server production

Temuan #15: File: /phpmyadmin/	HIGH
Deskripsi:	EXPOSED! phpMyAdmin terdeteksi — akses langsung ke manajemen database (HTTP 200, 17126 bytes)
Rekomendasi:	Hapus phpMyAdmin dari production atau batasi akses via IP allowlist

Temuan #16: X-Frame-Options	MEDIUM
Deskripsi:	Mencegah clickjacking via iframe
Rekomendasi:	Tambahkan header: X-Frame-Options: DENY atau SAMEORIGIN

Temuan #17: X-Content-Type-Options	MEDIUM
Deskripsi:	Mencegah MIME-type sniffing
Rekomendasi:	Tambahkan header: X-Content-Type-Options: nosniff

Temuan #18: File: /server-status	MEDIUM
Deskripsi:	EXPOSED! Apache server-status exposed — info koneksi aktif & performa (HTTP 200, 17126 bytes)
Rekomendasi:	Batasi akses ke /server-status hanya dari IP internal

Temuan #19: File: /server-info	MEDIUM
Deskripsi:	EXPOSED! Apache server-info exposed (HTTP 200, 17126 bytes)
Rekomendasi:	Batasi akses hanya dari IP internal

Temuan #20: File: /admin/	MEDIUM
Deskripsi:	EXPOSED! Admin panel terdeteksi — perlu verifikasi apakah dilindungi autentikasi (HTTP 200, 17666 bytes)
Rekomendasi:	Pastikan admin panel dilindungi autentikasi kuat + IP allowlist

Temuan #21: File: /administrator/	MEDIUM
Deskripsi:	EXPOSED! Administrator panel (Joomla-style) terdeteksi (HTTP 200, 17126 bytes)
Rekomendasi:	Lindungi dengan autentikasi + ubah URL default

Temuan #22: File: /error.log	MEDIUM
Deskripsi:	EXPOSED! Error log exposed — bisa berisi path internal, stack trace, info sensitif (HTTP 200, 17126 bytes)
Rekomendasi:	Pindahkan log ke luar document root

Temuan #23: File: /access.log	MEDIUM
Deskripsi:	EXPOSED! Access log exposed — berisi IP pengunjung & request history (HTTP 200, 17126 bytes)
Rekomendasi:	Pindahkan log ke luar document root

Temuan #24: File: /debug.log	MEDIUM
Deskripsi:	EXPOSED! Debug log exposed (HTTP 200, 17126 bytes)
Rekomendasi:	Nonaktifkan debug mode & hapus log dari document root

Temuan #25: File: /api-docs	MEDIUM
Deskripsi:	EXPOSED! API documentation exposed (HTTP 200, 17126 bytes)
Rekomendasi:	Batasi akses ke dokumentasi API

Temuan #26: XML-RPC Endpoint	MEDIUM
Deskripsi:	xmlrpc.php aktif — bisa disalahgunakan untuk brute force dan DDoS amplification
Rekomendasi:	Disable XML-RPC jika tidak digunakan, atau batasi aksesnya

Temuan #27: REST API User Enumeration	MEDIUM
Deskripsi:	REST API /wp-json/wp/v2/users mengekspos daftar user — attacker bisa enumerate username dengan mudah
Rekomendasi:	Disable atau batasi akses ke REST API users endpoint. Pakai plugin seperti Disable REST API atau filter di functions.php

Temuan #28: X-XSS-Protection	LOW
Deskripsi:	Mengaktifkan filter XSS bawaan browser (legacy)
Rekomendasi:	Tambahkan header: X-XSS-Protection: 1; mode=block (atau gunakan CSP sebagai pengganti)

Temuan #29: Referrer-Policy	LOW
Deskripsi:	Mengontrol informasi referrer yang dikirim browser
Rekomendasi:	Tambahkan header: Referrer-Policy: strict-origin-when-cross-origin

Temuan #30: Permissions-Policy	LOW
Deskripsi:	Mengontrol akses fitur browser (kamera, mikrofon, geolokasi)
Rekomendasi:	Tambahkan header: Permissions-Policy: geolocation=(), camera=(), microphone=()

Temuan #31: Server (Info Leak)	LOW
Deskripsi:	Terdeteksi: cloudflare — Membocorkan versi web server (misal: Apache/2.4.41)
Rekomendasi:	Sembunyikan atau hapus header Server dari response

Temuan #32: File: /wp-admin/	LOW
Deskripsi:	EXPOSED! WordPress admin panel default (HTTP 200, 17126 bytes)
Rekomendasi:	Pertimbangkan mengubah URL wp-admin atau membatasi akses via IP

Temuan #33: Info Disclosure: /readme.html	LOW
Deskripsi:	File '/readme.html' accessible — membocorkan informasi versi WordPress
Rekomendasi:	Blokir akses ke /readme.html via konfigurasi web server

4. DETAIL HASIL PER MODULE

Module 1 — HTTP Security Headers

Passed: **2** | Failed: **8** | Total: **10**

Check	Severity
Strict-Transport-Security	HIGH
Content-Security-Policy	HIGH
X-Frame-Options	MEDIUM
X-Content-Type-Options	MEDIUM
X-XSS-Protection	LOW
Referrer-Policy	LOW
Permissions-Policy	LOW
Server (Info Leak)	LOW

Module 2 — SSL/TLS Certificate

Passed: **6** | Failed: **0** | Total: **6**

Module 3 — Sensitive File Exposure

Passed: **13** | Failed: **22** | Total: **35**

Check	Severity
File: /dump.sql	CRITICAL
File: /configuration.php	CRITICAL
File: /backup.sql	CRITICAL
File: /db.sqlite3	CRITICAL
File: /database.sql	CRITICAL
File: /web.config	HIGH
File: /nginx.conf	HIGH
File: /backup.zip	HIGH
File: /backup.tar.gz	HIGH
File: /site.zip	HIGH
File: /phpinfo.php	HIGH
File: /info.php	HIGH
File: /phpmyadmin/	HIGH
File: /server-status	MEDIUM
File: /server-info	MEDIUM

Module 4 — CMS Detection

Passed: **1** | Failed: **1** | Total: **2**

Check	Severity
Info Disclosure: /readme.html	LOW

Module 5 — WordPress Plugin Scanner

Passed: **2** | Failed: **2** | Total: **4**

Check	Severity
XML-RPC Endpoint	MEDIUM
REST API User Enumeration	MEDIUM

Module 6 — Advanced SQL Injection

Passed: **1** | Failed: **0** | Total: **1**

Module 7 — Reflected XSS

Passed: **1** | Failed: **0** | Total: **1**

Module 9 — CSRF Protection

Passed: **1** | Failed: **0** | Total: **1**

Module 10 — Port Reconnaissance

Passed: **4** | Failed: **0** | Total: **4**

5. KESIMPULAN DAN SARAN PRIORITAS

Berdasarkan hasil audit, website **hybridsys.id** memiliki **5 kerentanan CRITICAL** dan **10 kerentanan HIGH** yang memerlukan perhatian segera.

Saran prioritas perbaikan:

1. [CRITICAL] File: /dump.sql
Hapus file database dump dari server production

2. [CRITICAL] File: /configuration.php
Pastikan PHP file diproses, bukan di-serve mentah

3. [CRITICAL] File: /backup.sql
Simpan backup di lokasi yang tidak bisa diakses publik

4. [CRITICAL] File: /db.sqlite3
Pindahkan database ke luar document root

5. [CRITICAL] File: /database.sql
Hapus dari document root

DISCLAIMER

Laporan ini dihasilkan secara otomatis oleh Spencer Web Security Audit Tool. Audit dilakukan pada waktu dan kondisi tertentu; kondisi keamanan website dapat berubah seiring waktu. Hasil audit ini hanya mencakup parameter yang diuji oleh tool dan tidak menggantikan audit keamanan manual oleh professional security expert. Beberapa temuan automated scanner dapat berupa false positive dan harus diverifikasi secara manual sebelum tindakan perbaikan diambil.

Generated by Spencer v2.0 — 19 May 2026